

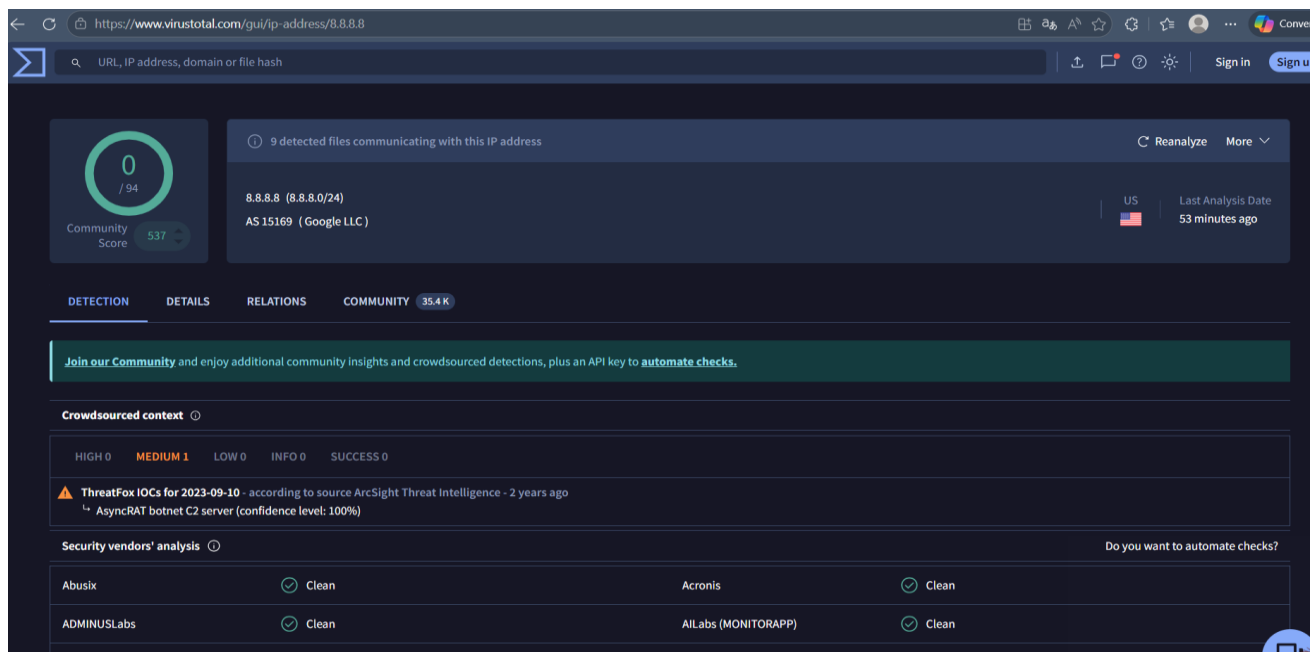
**NOM : ALIAWY MFAM SAKER RICHLAND**

## **COMPTE RENDU – TP 1.3 : INTRODUCTION A LA THREAT INTELLIGENCE ET RECHERCHE DE VULNERABILITES**

### **1-INTRODUCTION**

La Threat Intelligence (renseignement sur les menaces) consiste à collecter, analyser et exploiter des informations sur des menaces actuelles ou potentielles. En cybersécurité, elle permet aux équipes SOC (Security Operations Center) d'anticiper les attaques plutôt que de simplement les subir. Ce TP montre comment un analyste utilise des sources publiques (OSINT) pour évaluer la dangerosité d'une IP et les vulnérabilités de services exposés.

### **2- ANALYSE D'UNE ADRESSE IP PUBLIQUE (8.8.8.8)**



**Interprétation :**

- L'IP 8.8.8.8 (Google DNS) affiche un score de réputation propre (aucune détection malveillante).
- Quelques rapports signalent une possible utilisation par du contenu hébergé chez Google, mais rien d'actif ou de dangereux.
- Activité : serveur DNS légitime, très utilisé.

### Conclusion sur la dangerosité :

Cette IP n'est pas malveillante. Elle est connue et fiable. Un SOC ne devrait pas la bloquer sans raison spécifique (ex : politique interne).

### 3. ANALYSE DES SERVICES (A PARTIR D'UN SCAN NMAP)

```
(aliawy@kali)-[~]
$ nmap -sV 192.168.56.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 19:13 CEST
Failed to resolve "-".
Bare '-': did you put a space between '--'?
Failed to resolve "sV".
Nmap scan report for 192.168.56.10
Host is up (0.012s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 0.89 seconds

(aliawy@kali)-[~]
$ searchsploit apache
```

| Exploit Title                                                                 | Path                        |
|-------------------------------------------------------------------------------|-----------------------------|
| Apache (Windows x86) - Chunked Encoding (Metasploit)                          | windows_x86/remote/16782.rb |
| Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution               | php/remote/29290.c          |
| Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner             | php/remote/29316.py         |
| Apache - Arbitrary Long HTTP Headers (Denial of Service)                      | multiple/dos/360.pl         |
| Apache - Arbitrary Long HTTP Headers Denial of Service                        | linux/dos/371.c             |
| Apache - Denial of Service                                                    | linux/dos/18221.c           |
| Apache - httpOnly Cookie Disclosure                                           | multiple/remote/18442.html  |
| Apache - Remote Memory Exhaustion (Denial of Service)                         | multiple/dos/17696.pl       |
| Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-cgi' Directory Listing            | cgi/remote/20435.txt        |
| Apache 1.0/1.2/1.3 - Server Address Disclosure                                | multiple/remote/21067.c     |
| Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Server 1.12/1.1/2.0 - a nph-test-cgi | multiple/dos/19536.txt      |

### Explication des vulnérabilités :

Plusieurs exploits sont listés, dont un RCE (Remote Code Execution) via le chemin **/cgi-bin/**. Cette version d'Apache est vulnérable à la CVE-2021-41773 (path traversal) et CVE-2021-42013 (contournement de correctif).

### 3. Étude d'une CVE (exemple : CVE-2021-41773)

VULNERABILITIES

 **CVE-2021-41773 Detail**

#### Description

A flaw was found in a change made to path normalization in Apache HTTP Server 2.4.49. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution. This issue is known to be exploited in the wild. This issue only affects Apache 2.4.49 and not earlier versions. The fix in Apache HTTP Server 2.4.50 was found to be incomplete, see CVE-2021-42013.

**Metrics**

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

**CVSS 3.x Severity and Vector Strings:**

 **NIST NVD** **Base Score:** 9.8 **CRITICAL** **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:II/C:H/I:H/A:H

- **Description** : Vulnérabilité de traversée de chemin dans Apache 2.4.49, permettant d'accéder à des fichiers hors du répertoire web. Avec certaines configurations, elle mène à l'exécution de code à distance.
- **Impact** : Lecture de fichiers sensibles (passwd, clés), voire prise de contrôle du serveur.
- **Niveau de gravité** : Critique (CVSS 9.8/10) – exploitation à distance, sans authentification.

- **Exploitation possible :** Oui, des preuves de concept existent (curl, Metasploit). Un attaquant peut exécuter des commandes système si les CGI sont activés.

## 5- UTILISATION AVANCEE DE SEARCHSPOIT

Option    Rôle    Exemple    Utilité

-x <chemin>    Afficher le contenu texte d'un exploit    searchsploit -x exploits/linux/remote/50446.py    Comprendre le fonctionnement de l'exploit sans l'exécuter.

-m <id>    Copier un exploit dans le répertoire courant    searchsploit -m 50446    Permettre une analyse locale ou une compilation/modification sécurisée.

--exact    Recherche exacte (sans mot-clé élargi)    searchsploit --exact "Apache 2.4.49"    Éviter les faux positifs quand le service a un nom générique

## 6- ANALYSE GLOBALE DE SECURITE

### Risques identifiés :

- Serveur Apache obsolète (2.4.49) → vulnérabilités RCE critiques.
- Service SSH en version 7.6p1 (à vérifier si vulnérabilités connues).
- L'IP analysée (8.8.8.8) n'est pas un risque, mais le serveur local 192.168.56.10 l'est.

### Service le plus dangereux :

Apache 2.4.49 – car il permet une prise de contrôle à distance via une simple requête HTTP.

### Actions recommandées :

- Mettre à jour Apache vers la dernière version stable ( $\geq 2.4.51$ ).
- Désactiver les modules inutiles (cgi, autoindex).

- Appliquer un WAF (ModSecurity) temporairement si la mise à jour n'est pas immédiate.
- Réévaluer l'exposition du SSH (changer les mots de passe, utiliser clés).

## **7. LIEN AVEC L'ENTREPRISE**

Un SOC utilise la Threat Intelligence pour :

- Enrichir les alertes (ex : une IP apparait sur VirusTotal → prioriser).
- Anticiper : en surveillant les CVE des logiciels utilisés, le SOC peut patcher avant qu'un attaquant n'exploite.
- Proactivité : les recherches OSINT sur ses propres actifs (shodan, crt.sh) permettent de corriger des fuites d'informations.

Dans ce TP, un analyste aurait détecté Apache vulnérable avant qu'un exploit ne circule massivement.

## **7. CONCLUSION**

### **Ce que j'ai appris :**

- Utiliser VirusTotal pour juger rapidement la réputation d'une IP.
- Chercher des exploits avec searchsploit et interpréter les CVE.
- L'importance de l'OSINT en défense.

### **Limites de l'analyse :**

- Une IP propre aujourd'hui peut devenir malveillante demain.
- Un exploit connu n'est pas forcément utilisable (dépend de la configuration).
- Les sources OSINT publiques ne remplacent pas une analyse forensique approfondie.

## **COMPETENCES ACQUISES :**

L'information est une arme à double tranchant. Savoir chercher des vulnérabilités permet de mieux défendre son périmètre et d'adopter une posture proactive.